

1. "disk"ombobulate (Hard)

Flow giải bài:

.adl disk image → FTK Imager

↓

Hint đề bài → Chrome artifact → Login Data

↓

strings → SQLite → earlybird.bksec.vn → Flag part 2, encrypted pass_value dạng hex

↓

Cấu trúc blob Chrome v10 → iv, ciphertext

↓

Local State → encrypted key (encoded Base64) → decode → bỏ prefix DPAPI → blob.bin

↓

SID của user → encrypted masterkey

↓

Python script → flag part 2

↓

Desktop → fake flag → flag part 3

↓

Downloads → SimpleNote Installer.exe → check UWP

↓

Package name trong AppData/Local/Packages

↓

Strings toàn bộ folder → flag part 1 trong 000003.log

↓

Flag BKSEC{...}

Thử thách

2 lượt giải



"disk"ombobulate

493

hard

👍 0 🗨️ 0

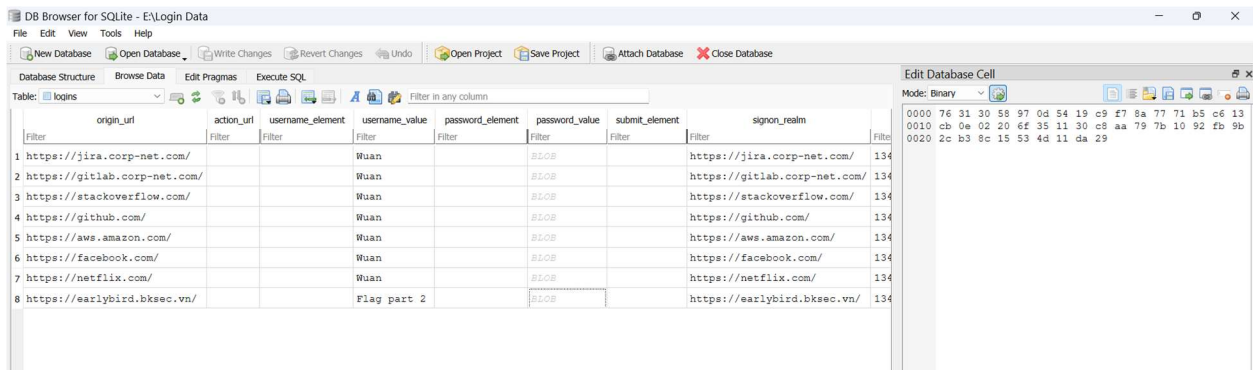
Đang thường thức một tập Sherlock Holmes thì chuông điện thoại reo - một cuộc gọi khẩn từ phòng điều tra. Họ vừa bắt giữ một nghi phạm và thu được ổ cứng của hắn. Theo lời khai ban đầu, nghi phạm đang truy cập một trang web bí mật để nhận nhiệm vụ tiếp theo thì bị ập vào bắt, chưa kịp trở tay. Bằng nghiệp vụ, đồng đội tôi đã lấy được mật khẩu truy cập máy tính của nghi phạm: wuan. Tuy nhiên đồng bọn của y đã can thiệp được vào quá trình điều tra và xóa dữ liệu trên máy. May mắn là tôi vẫn khôi phục được một vài dữ liệu. Chúng tôi cần biết kế hoạch tiếp theo của hắn ta.

"Elementary, my dear Watson" - Sherlock vẫn thường nói vậy. Lần này bạn có thể giúp tôi được không?

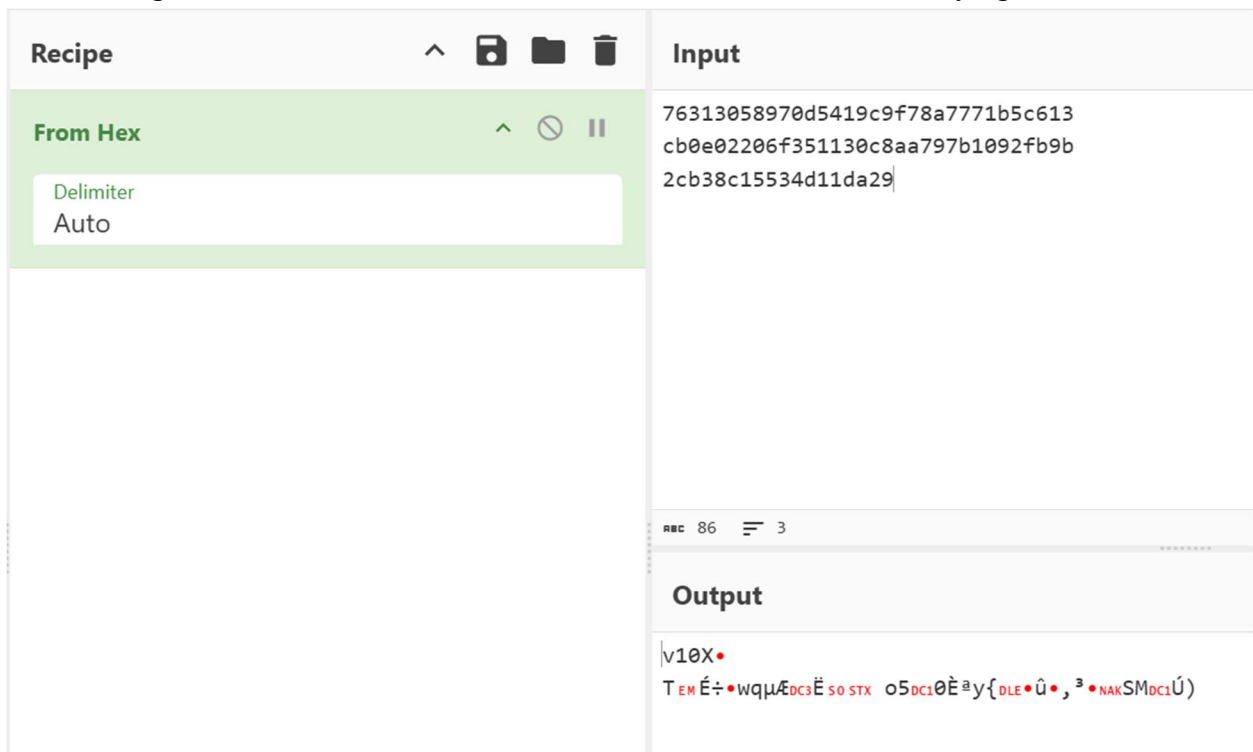
Đề bài cung cấp 1 file disk .ad1, mở với FTK Imager và từ gợi ý của đề bài, nghi phạm đã truy cập vào một trang web bí mật nên em đã tìm đến file Login Data ở đường dẫn "C__\NONAME [NTFS]\[root]\Users\Wuan\AppData\Local\Google\Chrome\User Data\Default". Dùng qua lệnh strings thì em thấy wuan đã truy cập vào trang web <http://earlybird.bksec.vn>, và ẩn ý tới Flag part 2.

```
luongdung@DESKTOP-CBPS8LU:/mnt/e$ strings "login data"
SQLite format 3
last_compatible_version40
version41
mmap_status-1
last_compatible_version
version
#      mmap_status
https://earlybird.bksec.vn/Flag part 2v10X
)https://earlybird.bksec.vn/
```

Vì đây là một file SQLite database nên em đã sử dụng DB Browser for SQLite để mở file



Vậy Flag part 2 là username khi đăng nhập web nói trên, và password value có dữ liệu bị mã hóa đang hiển thị ở dạng hex. Với prefix v10 cho biết Chrome version 80 trở đi sử dụng AES-256-GCM để mã hóa mật khẩu, và đoạn hex vừa rồi có ý nghĩa



76 31 30

← "v10" prefix (3 bytes)

58 97 0d 54 19 c9 f7 8a 77 71 b5 c6

← IV hoặc nothing (12 bytes)

13 cb 0e 02 20 6f 35 11 30 c8 aa

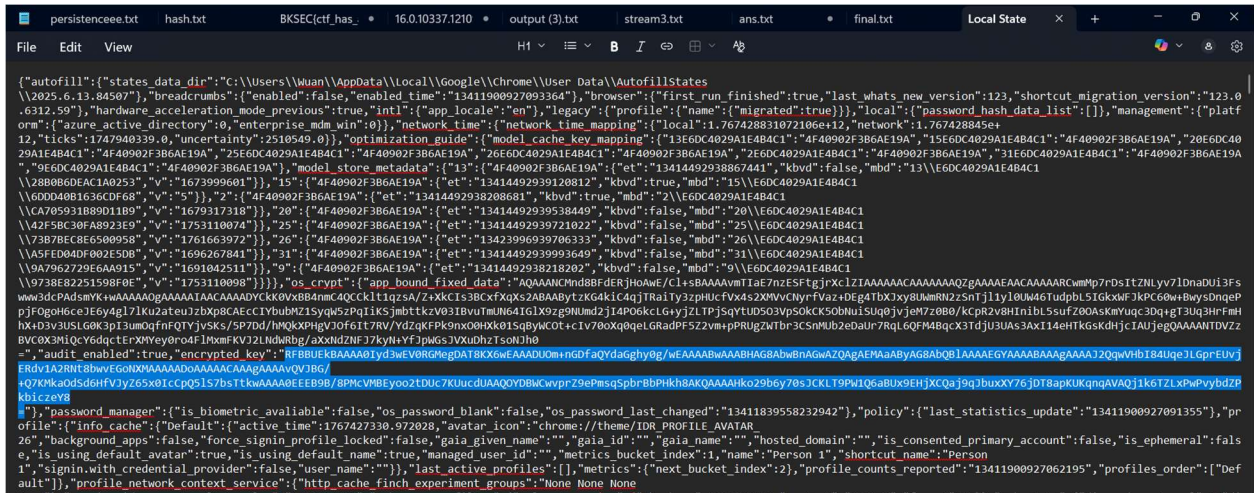
← ciphertext (11 bytes)

aa 79 7b 10 92 fb 9b 2c b3 8c 15 53 4d 11 da 29

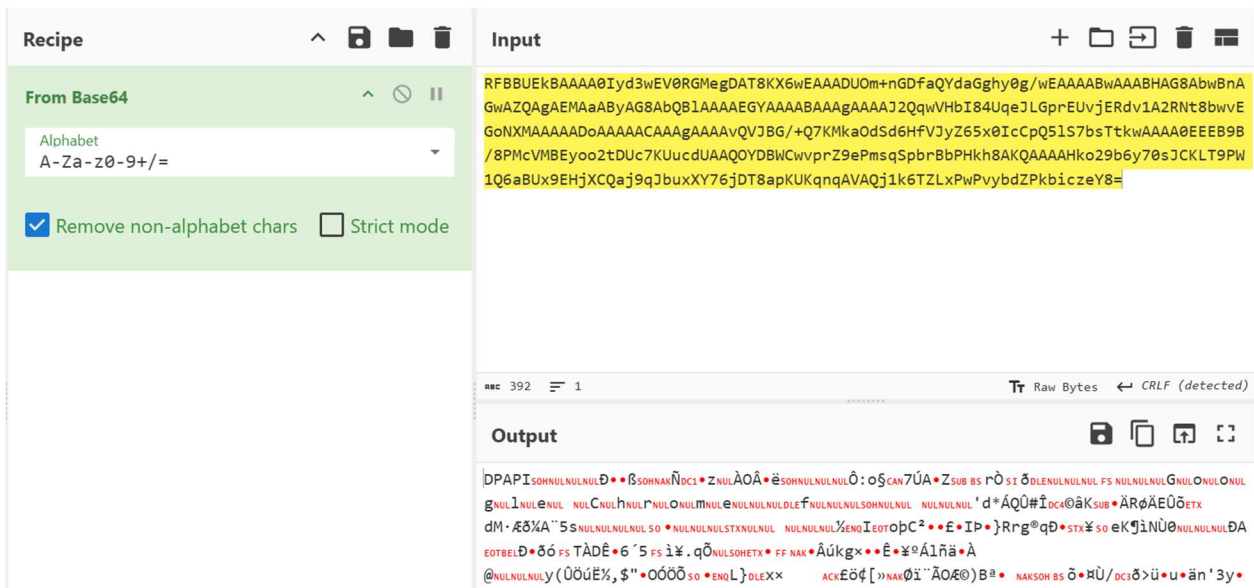
← GCM Tag (16 bytes)

Trong bài này, phần mã hex 58 97.... b5 c6 chính là iv để decrypt password.

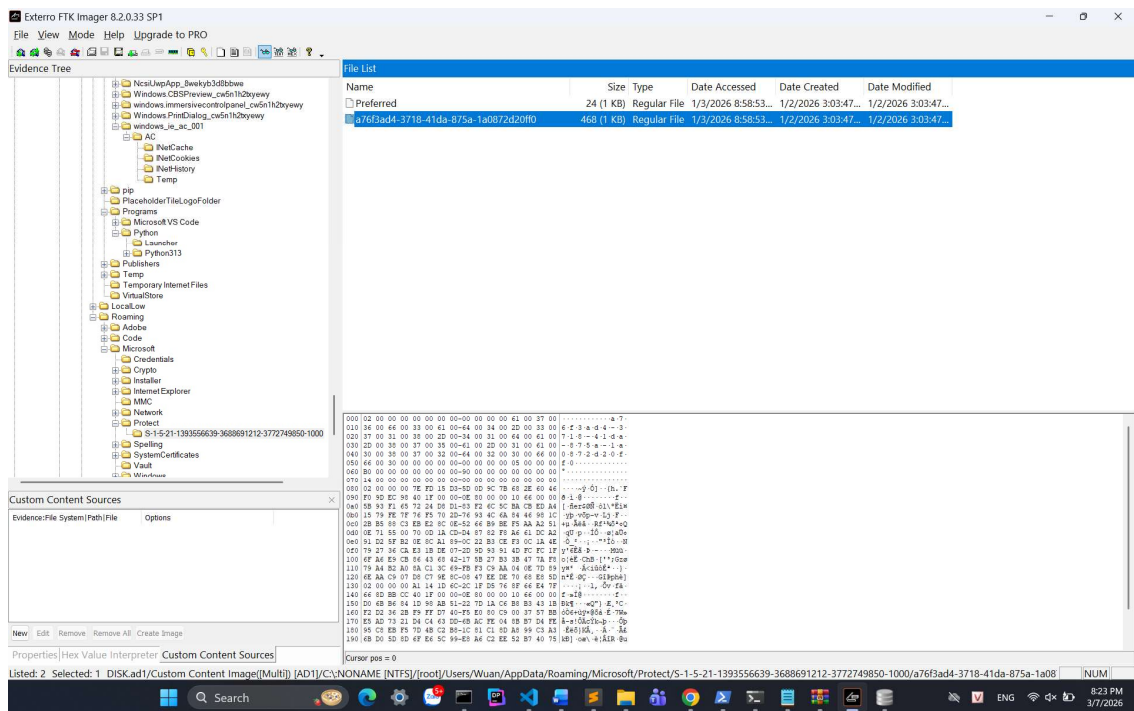
Vậy là em đã có key và ciphertext, phần còn lại để giải mã là key, nằm trong Local State (em AI để biết à)



Mở với notepad em xác định được encrypted key đã được encode Base64, tiến hành giải mã có được



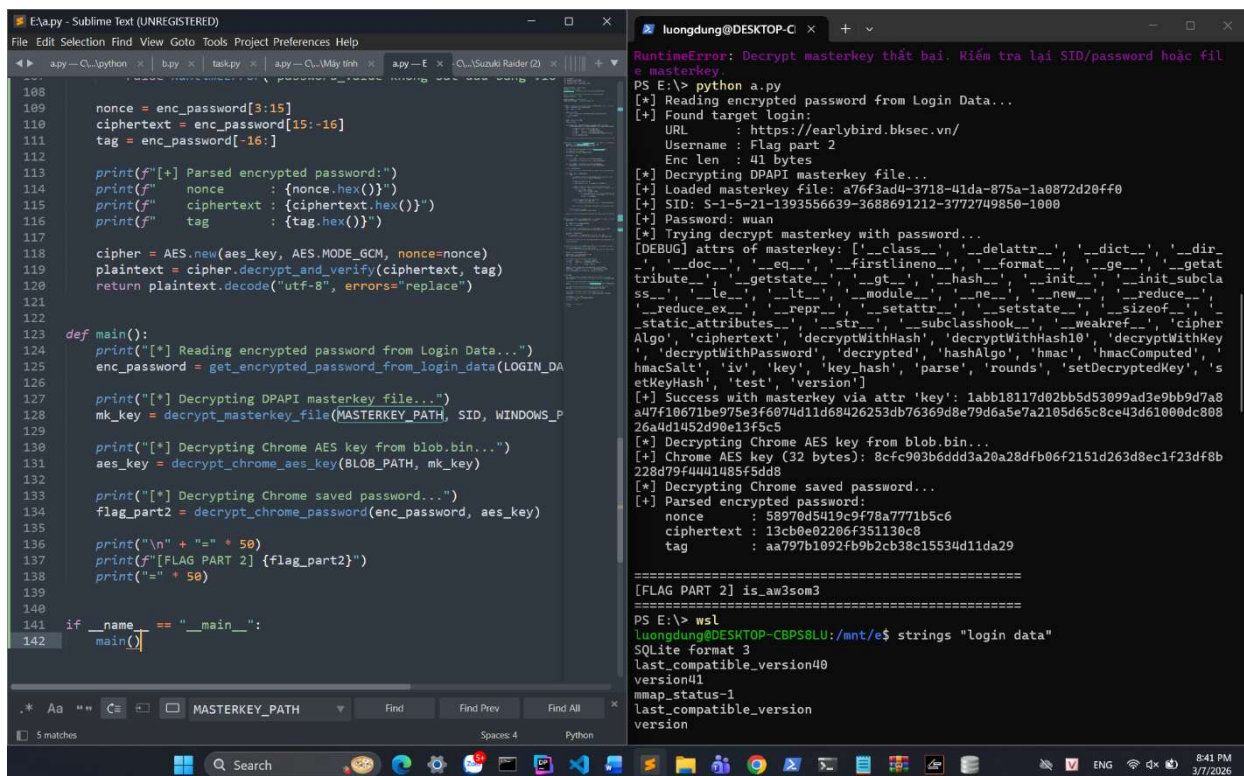
Thấy được DPAPI (phần còn lại là encrypted payload) là signature của Windows Data Protection API, đây là AES key nhưng bị khóa bằng Windows DPAPI, để giải mã cần masterkey của user Windows, SID của user và password đăng nhập (đề đã cho là wuan). Windows lưu masterkey tại đường dẫn AppData\Roaming\Microsoft\Protect\SID\... nên em tiếp tục tìm trong ổ đĩa



→ SID: S-1-5-21-1393556639-3688691212-3772749850-1000

Và a76f3ad4-3718-41da-875a-1a0872d20ff0 là DPAPI masterkey file của user.

Em extract tất cả các file liên quan, bao gồm cả blob.bin em download từ cyberchef sau khi bỏ 5 bytes đầu (DPAPI) và dùng AI tạo một đoạn python code tìm ra được password của username Flag part 2 trên web hay cũng chính là phần 2 của flag



- Password trong Login Data được mã hóa bằng AES-GCM
- AES key dùng để encrypt/decrypt password được mã hóa qua Windows DPAPI và lưu trong Local State
- DPAPI masterkey để giải mã blob chứa AES key lại dùng password của Windows để mã hóa

→ Flow của em là lần lượt giải mã, từ DPAPI masterkey rồi AES key và cuối cùng là Password

The screenshot displays the Extremo FTK Imager 8.2.0.33 SP1 application window. The main pane shows a file system tree for a disk labeled DISK.ad1. The tree structure includes:

- Custom Content Image ([Multi]) [AD1]
 - C:\NONAME [NTFS]
 - [root]
 - \$Extend
 - \$Recycle.Bin
 - Program Files
 - Program Files (x86)
 - ProgramData
 - Users
 - All Users
 - Default
 - Default User
 - Public
 - Wuan
 - .vscode
 - 3D Objects
 - AppData
 - Application Data
 - Contacts
 - Cookies
 - Desktop
 - fake_flag.txt
 - Documents
 - Downloads
 - ChromeSetup.exe
 - Favorites
 - Links
 - Local Settings
 - Music
 - My Documents
 - NelHood
 - OneDrive
 - Pictures
 - PrintHood
 - Recent
 - Saved Games
 - Searches
 - SendTo

The right pane shows a "File List" table with columns: Name, Size, Type, Date Av.

Name	Size	Type	Date Av.
flag_part_3	12 (1 KB)	Alternate ...	1/3/2020

Below the file list, there is a text area containing the string: `_isnt_it?)`

A small dialog box titled "Custom Content Sources" is open at the bottom left, showing a table with columns: Evidence, File System, Path, File, Options.

Evidence	File System	Path	File	Options

Vì SimpleNote không phải Win32 app mà là UWP (Universal Windows Platform), được cài từ Microsoft Store và data nằm trong “C___NONAME[NTFS][root]\Users\Wuan\AppData\Local\Packages”, chứ không nằm trong AppData/Roaming như thường. Em truy cập vào đường dẫn và thấy được package name của Simplenote.

Strings qua tất cả các file trong thư mục 22490Automatic.Simplenote_9h07f78gwnchp, em có được phần đầu của flag được lưu trong file
LocalCache/Roaming/Simplenote/IndexedDB/file_0.indexeddb.leveldb/000003.log

➔ FLAG: BKSEC{d1sk f0rensics is aw3s0m3 isnt it?}